

LP 0

# Introduction



# Intoduction



- Explore identity
- Identity administration concepts
- Authentication and authorization
- Auditing and other identity concepts



# Explore identity

# Why an identity?



# Why use an identity?

|                                             |                |    |
|---------------------------------------------|----------------|----|
| To be able to prove what we are             | Authentication | 1. |
| To get permission to do something           | Authorization  | 2. |
| To report on what was done                  | Auditing       |    |
| To be able to (self) administer an identity | Administration |    |

 **Authentication**

- User sign-on experience
- Trusted source(s)
- Federative protocols
- Level of assurance

 **Authorization**

- How and where are authorizations handled?
- Can a user access the resource and what can they do when they access it?

 **Administration**

- Single view management
- Application of business rules
- Automated requests, approvals, and access assignment
- Entitlement management

 **Auditing**

- Track who does what, when, where and how
- Focused alerting
- In-depth collated reporting
- Governance and compliance

# What is an identity provider (IdP)?

Active Directory  
Entra ID  
Microsoft Account

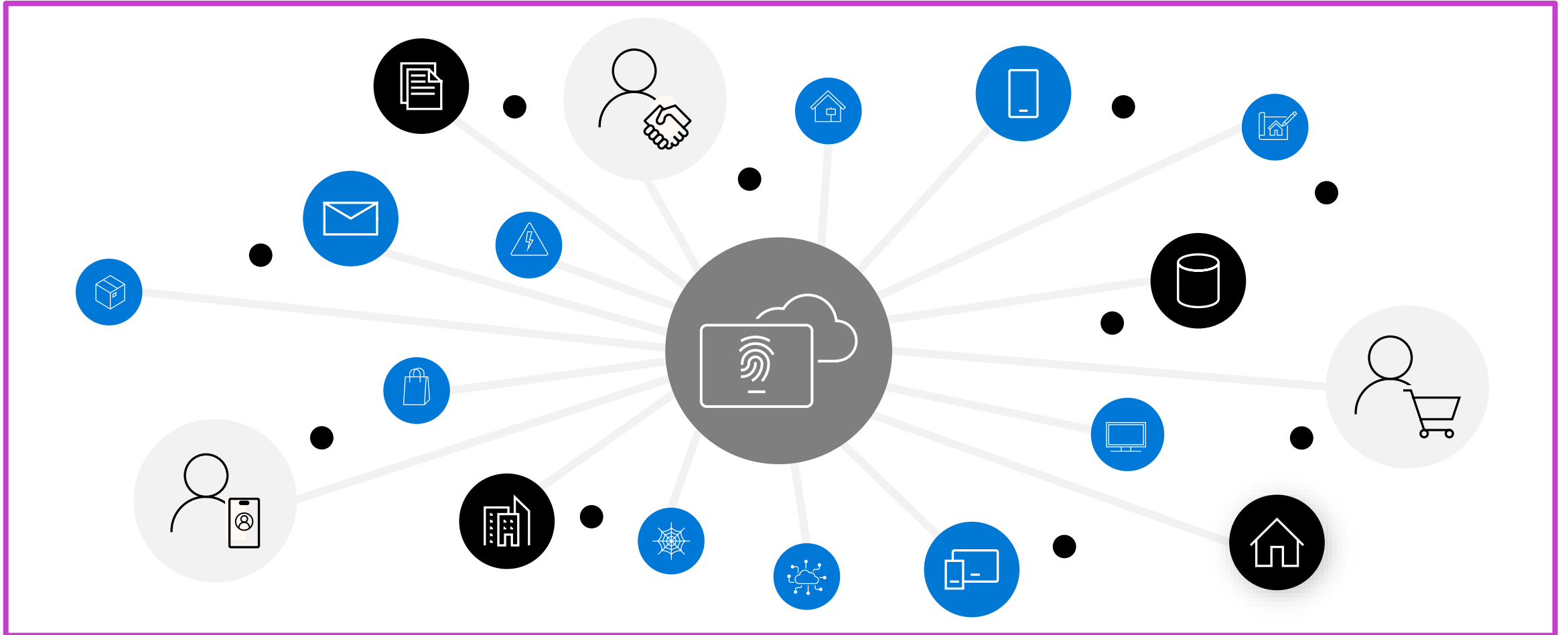
An identity provider (IdP) is a system that creates, manages and stores digital identities. Microsoft Entra ID is an example. The capabilities and features of identity providers can vary. The most common components are:

- A repository of user identities
- An authentication system
- Security protocols that defend against intrusion
- Someone we trust

Google  
Facebook  
Apple  
Okta  
...

# Identity is the control plane

Secure access for a connected world





# Identity administration concepts



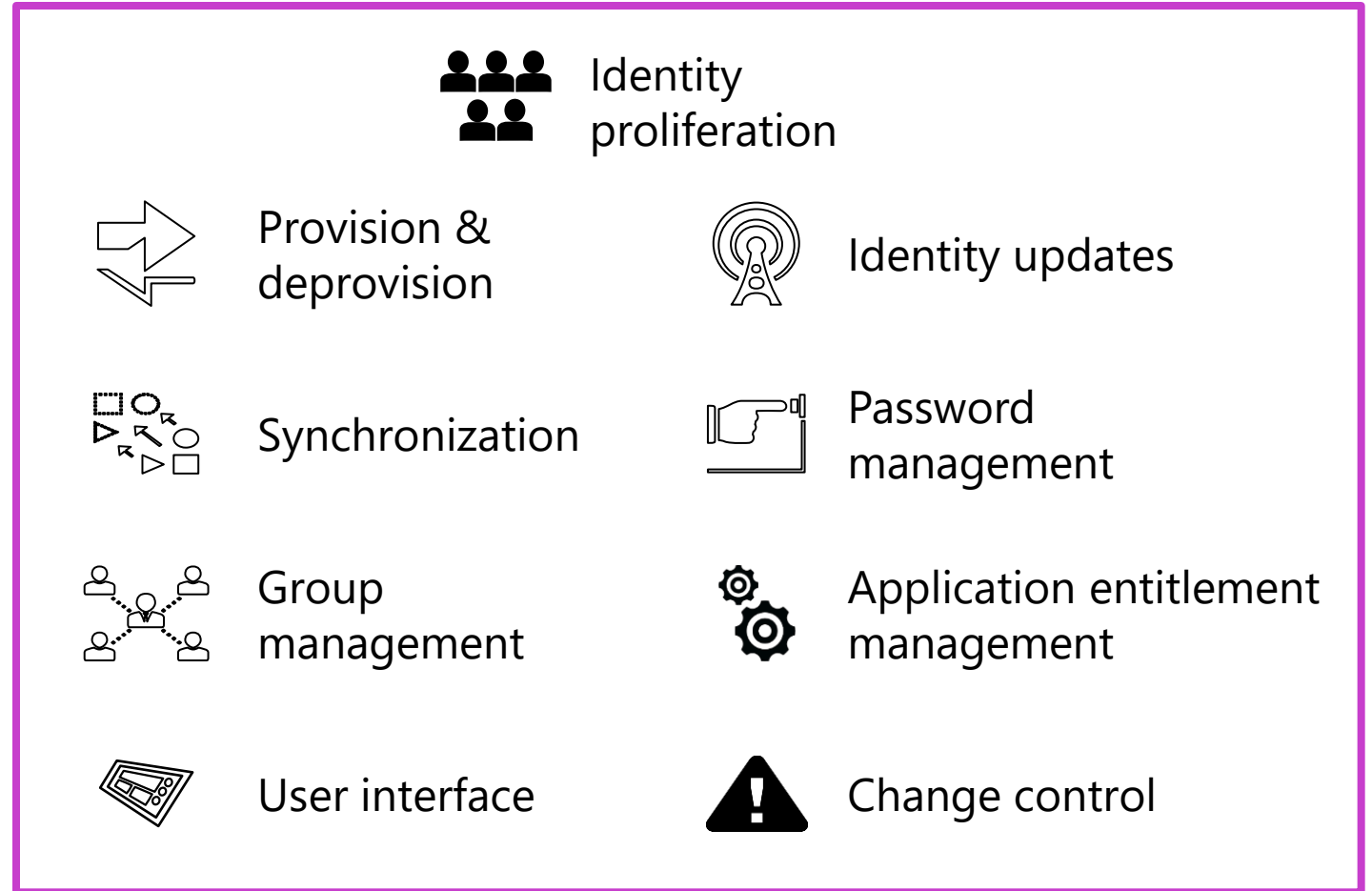


# Administration

How identity objects are managed, whether manually or automated, over the lifetime of the identity's existence.

## Administration provides:

- A system which is highly configurable around business processes.
- The agility to scale resources according to demand.
- Cost savings through the distribution and automation of management.
- Flexibility around synchronization, proliferation, and change control.



# Management automation with PowerShell or CLI

## Azure PowerShell

- Cross-platform PowerShell module, runs on Windows, macOS, Linux
- Requires Windows PowerShell or PowerShell

## CLI (command-line interface)

- Cross-platform command-line interface, installable on Windows, macOS, Linux
- Runs in Windows PowerShell, Cmd, Bash and other Unix shells.

| Scripting language | Action      | Command                                                                                                                                                                |
|--------------------|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Azure CLI          | Create User | <code>az ad user create --display-name "New User" --password "Password" --user-principal-name NewUser@contoso.com</code>                                               |
| Azure PowerShell   | Create User | <code>New-AzureADUser -DisplayName "New User" -PasswordProfile Password -UserPrincipalName "NewUser@contoso.com" -AccountEnabled \$true -MailNickName "Newuser"</code> |

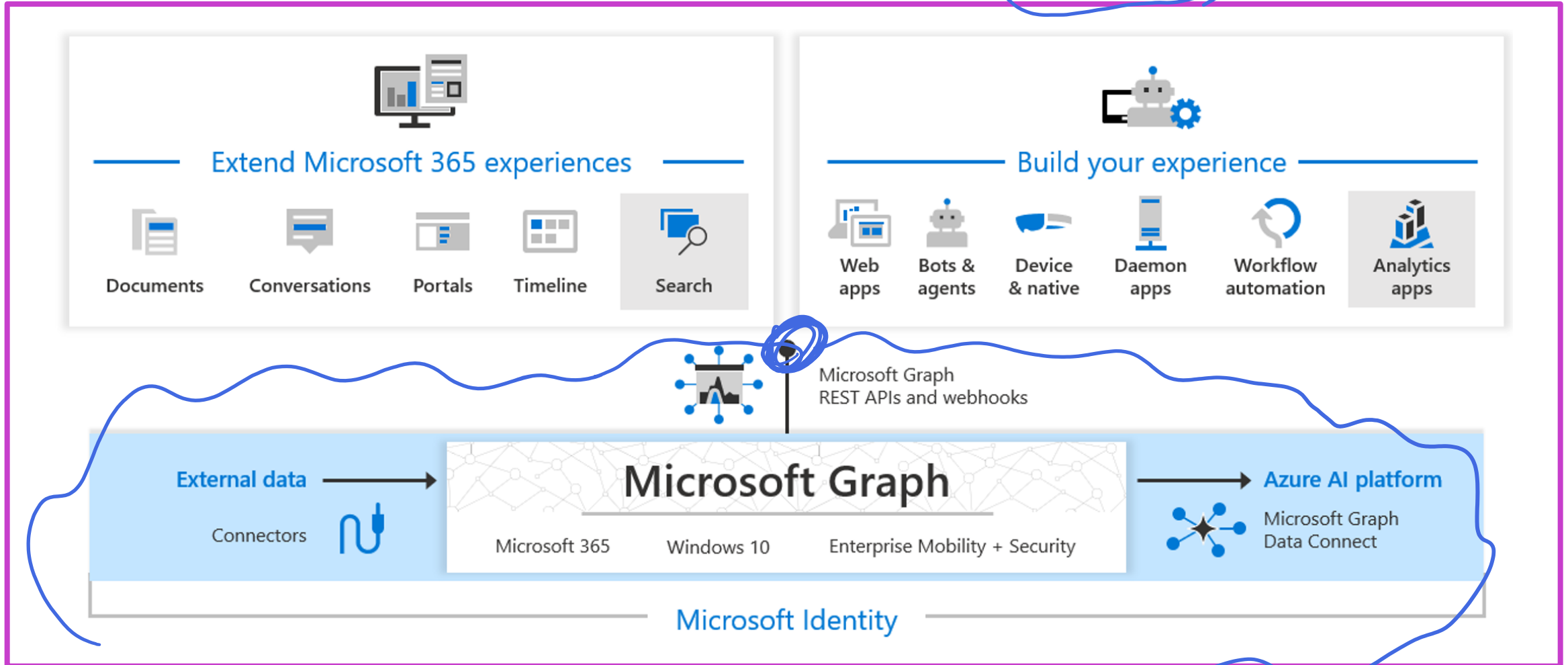
PowerShell  
Cmd lets

New-Mg User

Old (ADAL)  
New (MSAL)  
Microsoft Graph

# Microsoft Graph

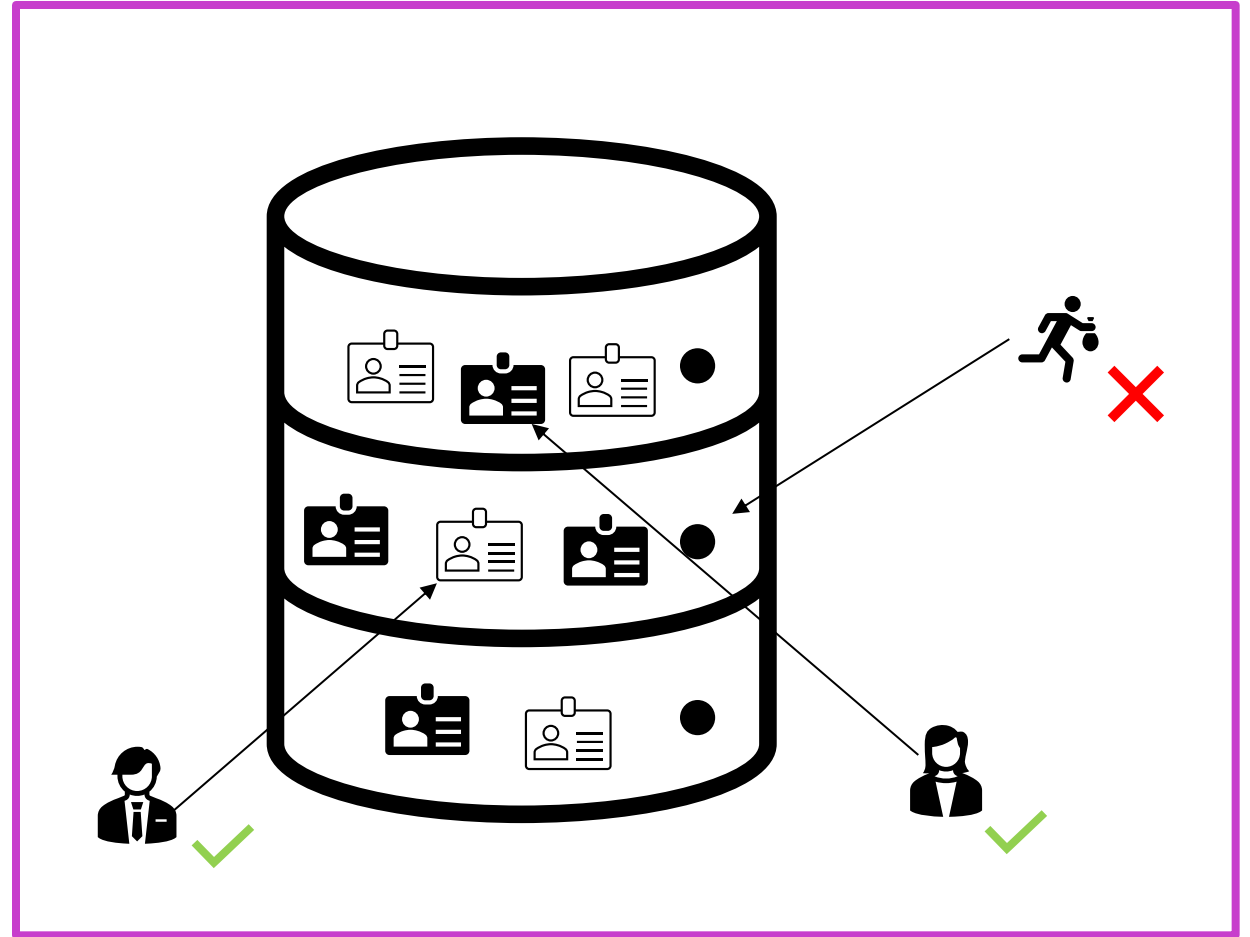
Microsoft Graph  
API  
New-MgUser  
Portale  
Entra ID  
Paul  
M365  
EXO  
SP  
Tenant



# Central Identity System

Centralized identity management or central identity system is a single identity tool where credentials are stored and managed, to provide authentication and authorization capabilities.

- Credentials are verified when stored
- Management is by single authority
  - admin or admin group
- Used for identity and access management

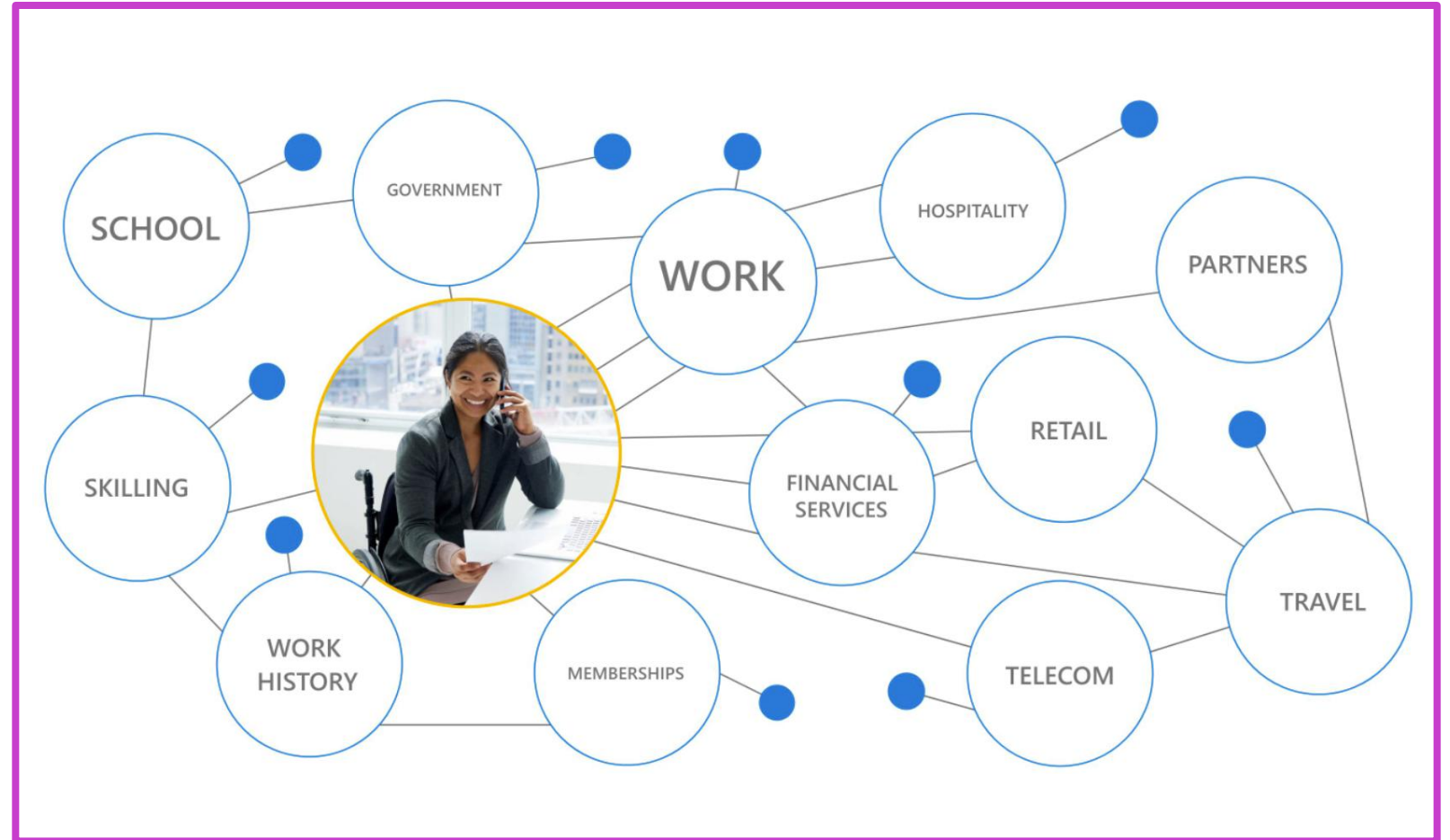


# Decentralized identity

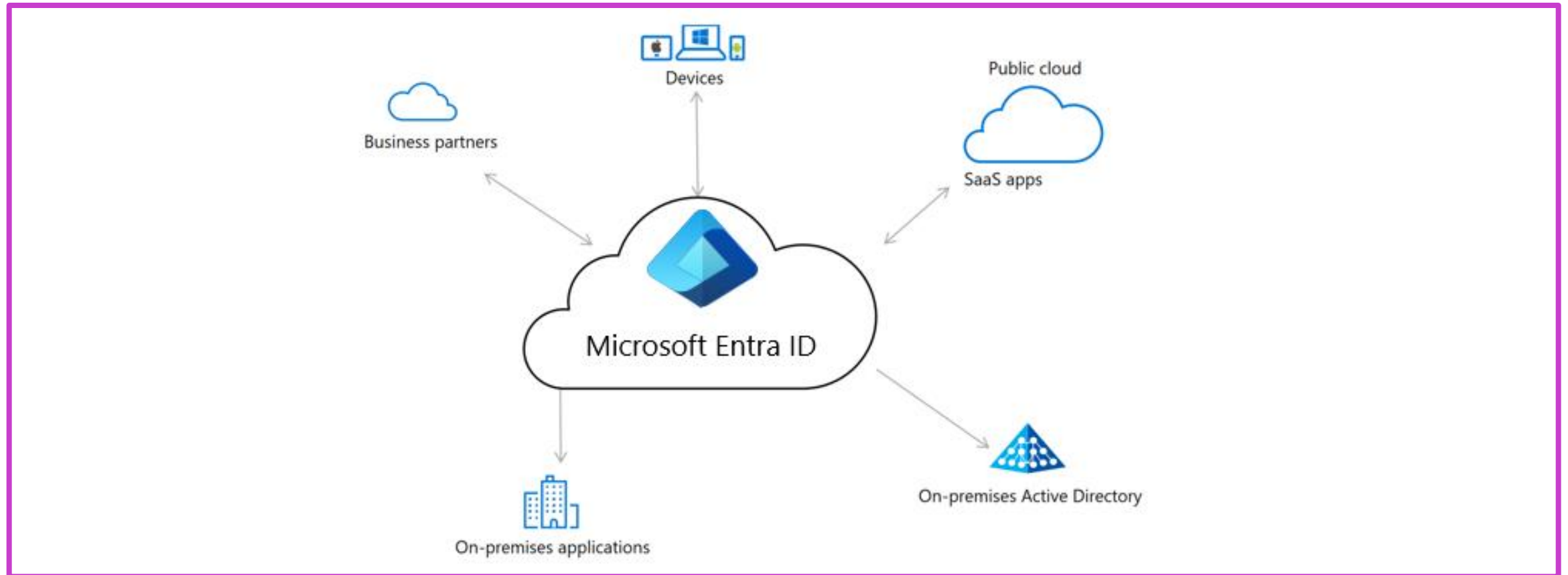
## What is decentralized identity?

- User-generated
- Self-owned
- Globally unique identifier
- Immutable
- Censorship resistant
- Tamper evasive

[Microsoft Decentralized Identity Whitepaper](#)



# Identity and access management solutions



An identity solution controls access to an organization's apps and data. Users, devices, and applications have identities.

# Microsoft Entra ID architecture and terms

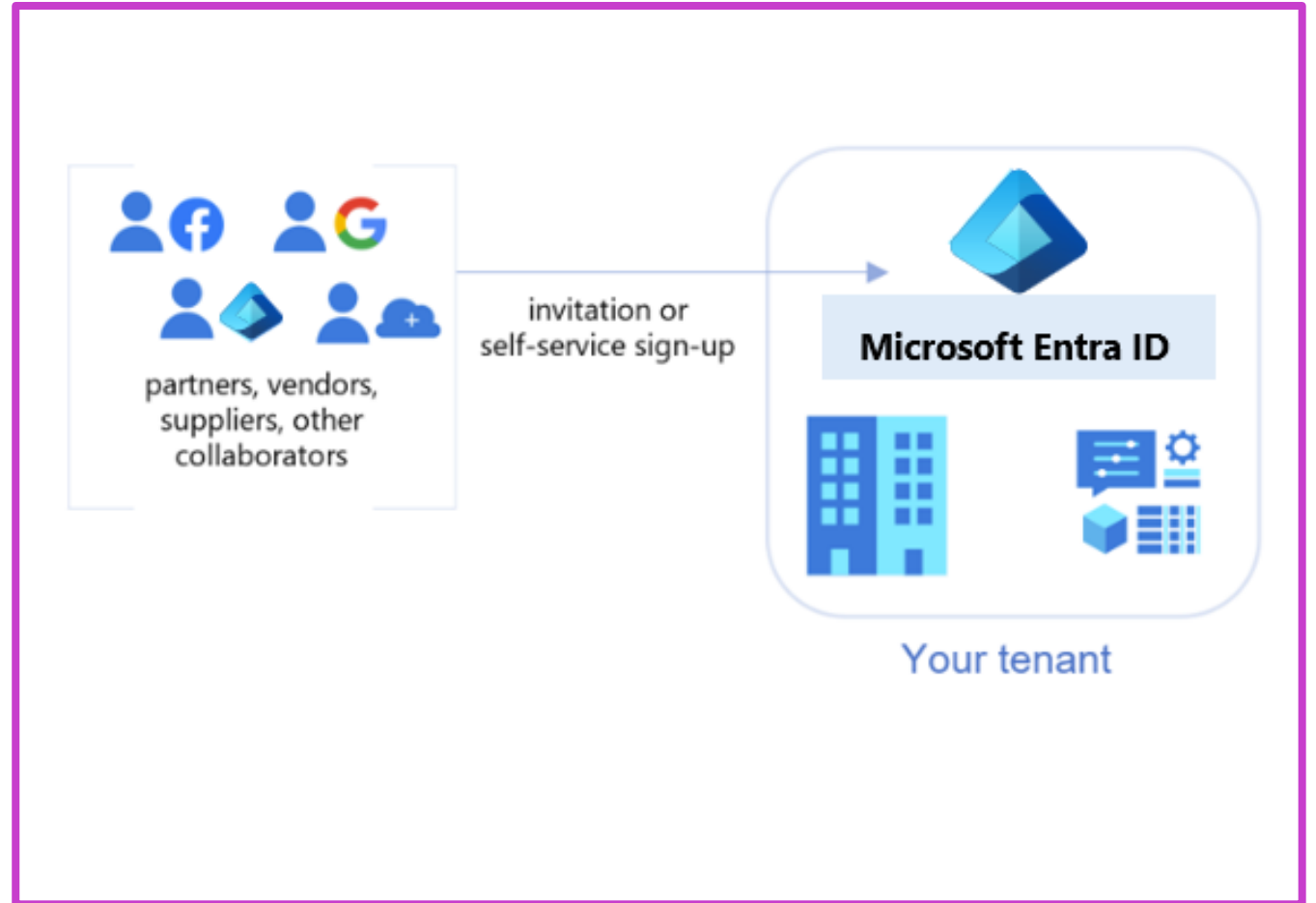
Microsoft Entra ID is a cloud-based identity and access management solution, with integrated security and a flat architectural design.

| Concept      | Definition                                                   | Usage                                                                                                 |
|--------------|--------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| Subscription | Pay over time for services and features.                     | Purchase specific Azure cloud services needed for your cloud solutions. There are many subscriptions. |
| Tenant       |                                                              | A tenant is a digital representation of your organization, like Contoso.com.                          |
| Identity     | An object in the Microsoft Entra ID that gets authenticated. | Used to assign rights and access to resources.                                                        |
| Account      | An identity that has data associated with it.                |                                                                                                       |
| User         | A verified account associated with a person.                 | Specific person who can be give access to resources.                                                  |



# What is Azure Business to Business (B2B)?

- Federation between two directories.
- Used to prevent creation of duplicate accounts for the same user across directories.
- Enables and simplifies organization collaboration.
- Create identities (called external identities) to easily assign resources.



# What is Microsoft Entra B2C?

## Customers

Social IDs, email, local accounts



Business and Government IDs



Securely authenticate your customers using their preferred identity provider

Capture login, preference, and conversion data for customers

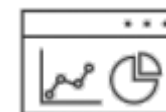
Provide branded (white label) registration and login experiences

## Business

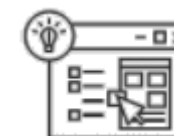
Apps and APIs



Analytics

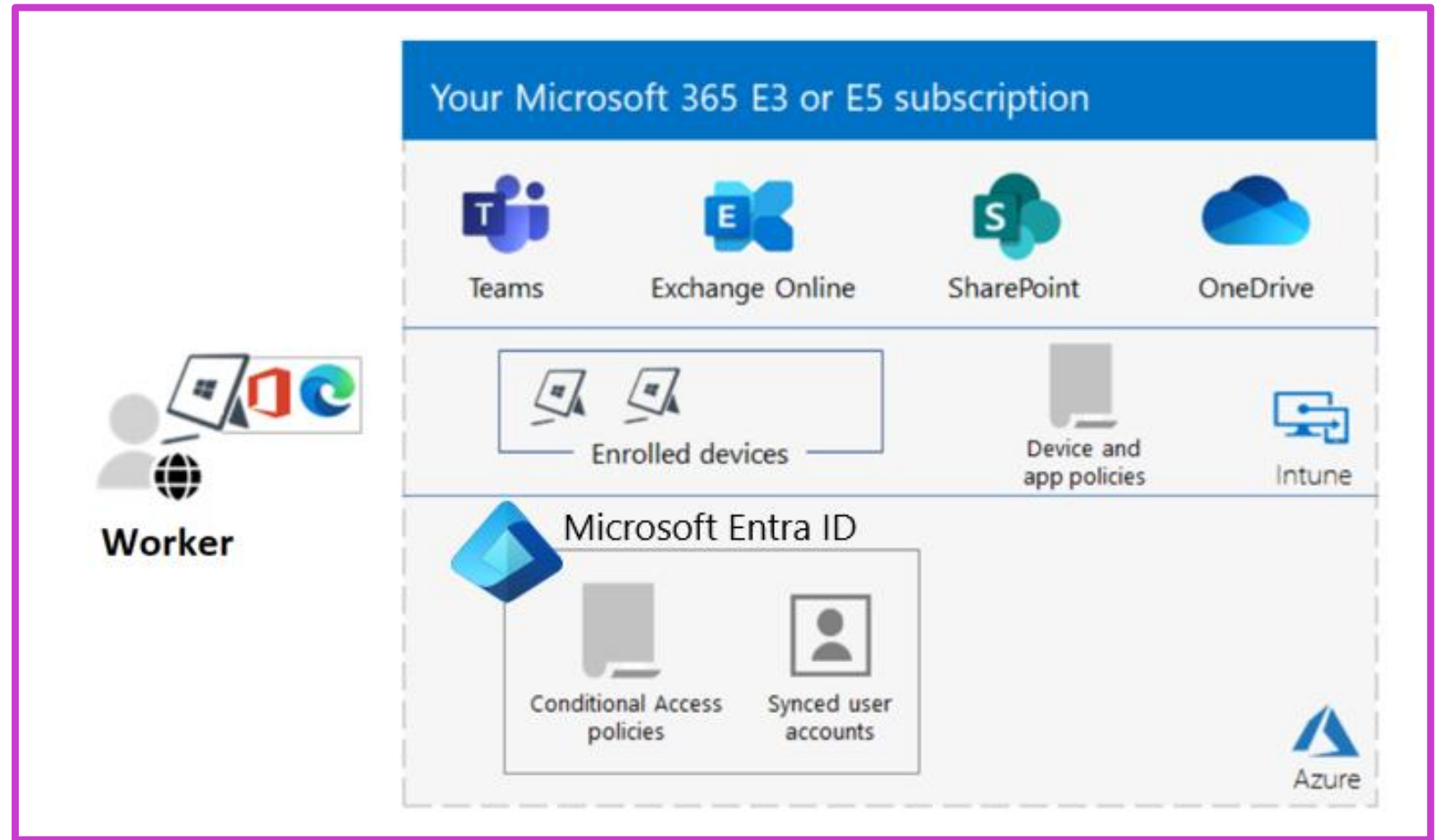


Integration with other systems



# Microsoft 365 using Microsoft Entra ID

Microsoft 365 uses Microsoft Entra ID to manage user identities behind the scenes.



# Compare Microsoft Entra ID to Microsoft Entra DS to on-premises AD DS

Kerberos

LDAP  
Gro

On Prem AD

✓ DC Sysvol

| Microsoft Entra Domain Services                                                                                                                                          | Microsoft Entra ID                                                                                                                                                                                                     | Active Directory Domain Services                                                                                                                                                           |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Provides managed domain services with a subset of fully-compatible traditional AD DS features such as domain join, group policy, LDAP, and Kerberos/NTLM authentication. | Cloud-based identity and mobile device management that provides user account and authentication services for resources such as Microsoft 365, the Azure portal, or SaaS applications.<br><br>New: Kerberos in Entra ID | Enterprise-ready lightweight directory access protocol (LDAP) server that provides key features such as identity and authentication, computer object management, group policy, and trusts. |

# Licenses and MAU

**License**—purchased agreement to allow users or guests to use a Microsoft technology.

Common SKU/licenses:

- Microsoft Entra ID P1 or P2 license
- Microsoft Entra ID Governance
- Microsoft 365/Office 365 license
- Microsoft 365 E5 + Security
- Windows license
- License needed per user on the service

**Monthly active users (MAU) billing**—pricing model for external users in Microsoft Entra ID.

- MAU billing available when you have a subscription
- Report of **active** external users run each month for billing
- First 50,000 MAUs free monthly (P1 and P2)
- Helps establish predictable pricing

# Authentication and authorization



# Authentication

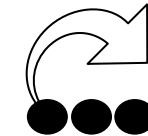
You validate someone's identity to confirm who they claim to be while providing an appropriate level of validation and security throughout the authentication transaction.

## Identity authentication provides

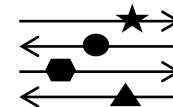
- Flexible, standards compliant, authentication that integrates across organizations
- Integration of disparate sources, applications, and protocols
- Employs many different industry-standard methods of validation and assurance



Convenience



Sources

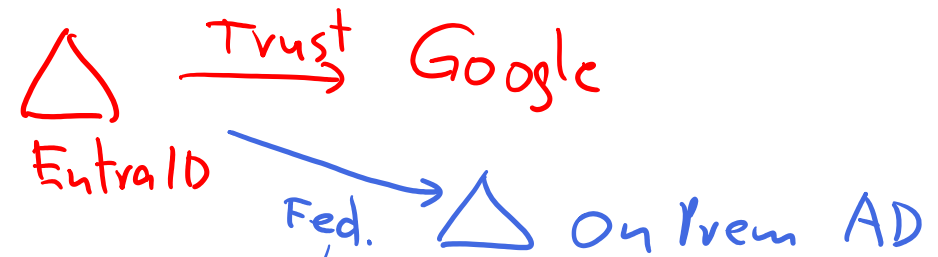


Protocols



Assurance

# Federated identity concepts



Federation is a collection of domains that have established trust. The level of trust may vary, but typically includes authentication and almost always includes authorization.

## Security Assertion Markup Language (SAML)

Open standard for exchanging authentication and authorization data between an identity provider and a service provider.

- The principal, generally a user
- The identity provider (IdP)
- The service provider (SP)

## Web Services Federation (WS-Fed)

An identity specification from a Web Services Security framework to provide single-sign-on via external identity exchange and authentication.

## OpenID Connect (OIDC)

OIDC extends the OAuth 2.0 authorization protocol for use as an authentication protocol, so that you can do single sign-on using OAuth.



# Claims-based identity in Microsoft Entra ID

When a user signs in, Microsoft Entra ID sends an ID token that contains a set of claims about the user. A claim is simply a piece of information, expressed as a key/value pair.

| Claims-based process (high level)                                                                                                                                                                                          | Types of security tokens                                                                                |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| <ol style="list-style-type: none"><li>1. User authenticates.</li><li>2. Identity provider sends claims.</li><li>3. App normalizes or augments claims.</li><li>4. App uses token to make authorization decisions.</li></ol> | <b>ID token</b> —used in OpenID Connect token used to authenticate a user.                              |
|                                                                                                                                                                                                                            | <b>Access token</b> —issued by OAuth 2.0 server, contains user information and resource to be accessed. |
|                                                                                                                                                                                                                            | <b>Refresh token</b> —token co-issued with the access token to allow the application to renew access.   |

# Other topics on claims-based authentication

| Claims-based topic          | Definition and usage                                                                                                                                            |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>JSON Web Token (JWT)</b> | Open standard definition (RFC 7519) of security token.                                                                                                          |
| <b>Claim</b>                | A group of value-pair items stored in a security token that define different information in the token. Common attributes: username, encryption type, and so on. |
| <b>Assertion</b>            | A package of data in the form of a token to share identity information.                                                                                         |
| <b>Attribute</b>            | A single value-pair of data within a security token.                                                                                                            |
| <b>Augmentation</b>         | The process by which an application adds app/user specific data into a security token.                                                                          |

# Authorization

Covers what an identity can access and what they are allowed to do once they gain access.

## Identity authorization provides

- Methods of assigning entitlement allowing for increased security and less administration.
- Ability to manage policy control.
- A way to simplify enforcement by standardizing on a common approach.



Entitlement type



Access policies



Enforcement

# Authorization—access tokens

| Access tokens                                             | ID tokens   | Refresh tokens                       |
|--------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>• User information</li><li>• Target resources</li><li>• Short lifespan</li><li>• OAuth 2.0</li></ul> | <ul style="list-style-type: none"><li>• Authenticate a user</li><li>• OpenID Connect</li></ul> | <ul style="list-style-type: none"><li>• Extra token to allow a new access to be requested</li><li>• OAuth 2.0</li></ul> |

# Common authorization approaches

| Authorization type                    | Description                                                                                  |
|---------------------------------------|----------------------------------------------------------------------------------------------|
| Access control lists (ACLs)           | Explicit list of resource access. Very granular, hard to maintain.                           |
| Role-based access control (RBAC)      | Grant access based on the user's role.                                                       |
| Attribute-based access control (ABAC) | Grant access based on one or more attributes of the user's current environment and identity. |
| Policy-based access control (PBAC)    | Role and policy combined to determine user access.                                           |

Microsoft Entra ID can support any of these methods and others, based on your business and security goals.

# Auditing and other identity concepts



# Auditing

Tracking who did what,  
when did they do it and  
how did they obtain access  
(who granted it)?

Identity auditing provides:

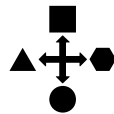
- Proactive/reactive reporting and alerts to enforce policies and identify problems quickly.
- Governance of auditing data ensures proper authorizations, historical accuracy, and compliance.
- Collation and centralization of audit data from disparate resources.



Collection



Access logging



Change logging



Alerting



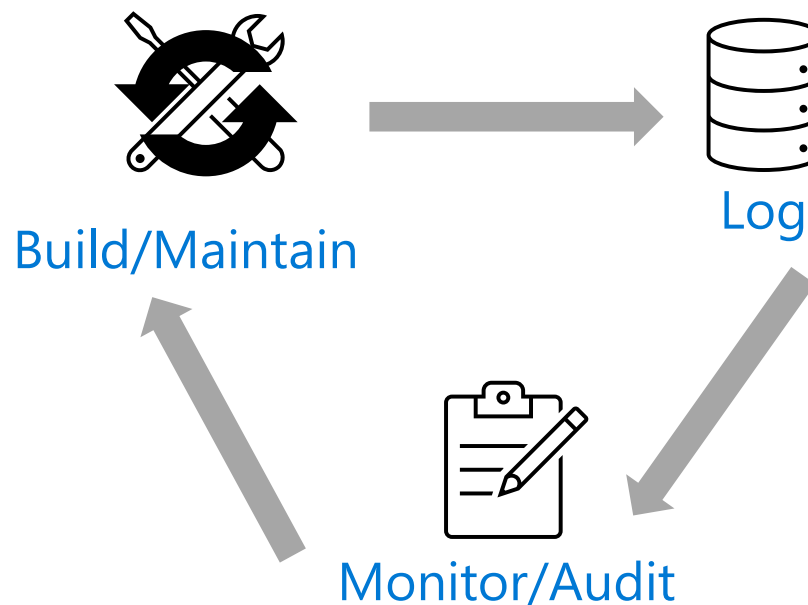
Reporting  
Methodology



Reporting types

# Audit, Report, and Monitor

When your identity solution built, you have to audit. Use the built-in reports and monitor tools to make sure your system is functioning securely and optimally.





# Monitoring

**Always think Zero Trust:** Verify explicitly—Use least privilege access—Assume breach

## Monitoring checklist:

- Applications have logs and metrics.
- Components are monitored and correlated with application telemetry.
- Key metrics, thresholds, and indicators are defined and captured.
- A health model defined, based on performance, and availability.
- Use Azure Service Health and Azure Resource Health for alerts.
- Monitor long-running workflows for failures.

## Monitoring services:

- Azure Monitor
- Application Insights
- Azure Service Health
- Azure Resource Health
- Azure Resource Manager
- Azure Policy

# Cryptography related to identity solutions

Cryptography is the process of converting data so that only a specific recipient will be able to read it, using a key.

## Cryptography within identity:

- **Hashing**—the creation of a statistically unique fixed length value to act as a unique identifier.
- Passwords are hashed instead of transmitted over the internet
- **Digital signatures**—sign a message so the receiver knows the origin of the message and that it has not been tampered with.
- **Encryption**—process of encoding data into cipher text for storage or transmission.

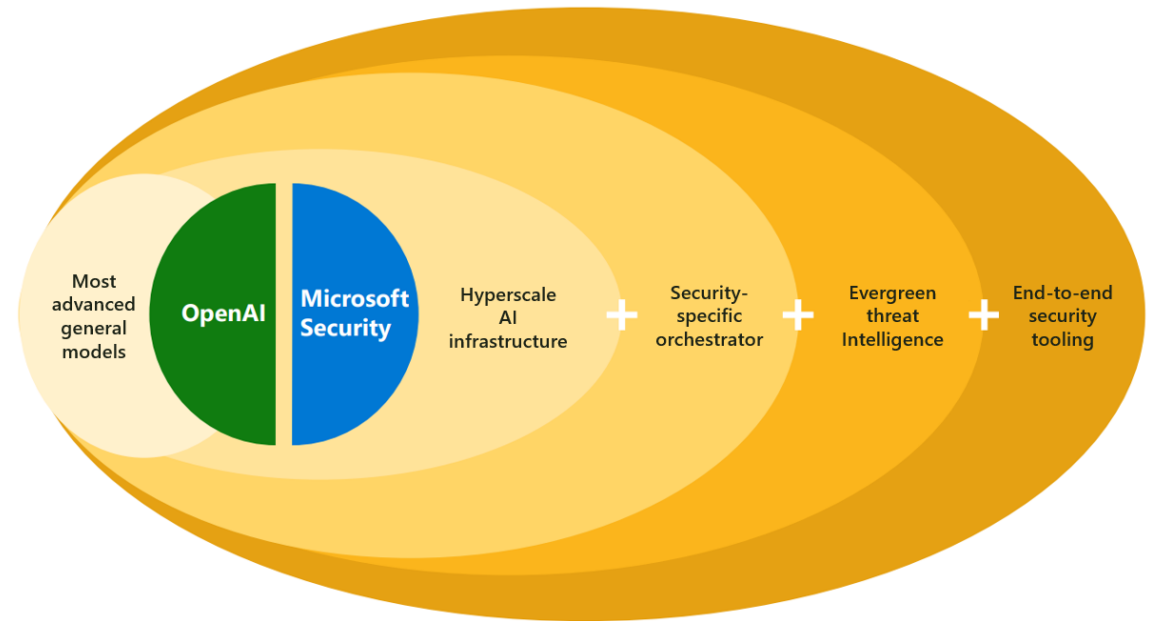
# Security Copilot



# Describe what Microsoft Security Copilot is

An AI-powered, cloud-based security analysis tool that enables analysts to respond to threats quickly, process signals at machine speed, and assess risk exposure more quickly than may otherwise be possible.

- Copilot combines powerful LLMs with a security-specific model from Microsoft.
- Copilot integrates with Microsoft and non-Microsoft sources.
- Copilot learns at machine speed to help analysts identify and respond to emerging threats.
- Enterprise data is protected by comprehensive enterprise compliance and security controls.

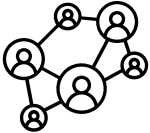


# Describe Microsoft Security Copilot – Use cases



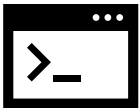
**Incident summarization.** Distil complex security alerts into concise actional summaries.

---



**Impact analysis.** Assess the potential impact of security incidents to enable quicker response times and streamlined decision-making.

---



**Reverse engineering of scripts.** Analyze complex command line scripts and translate them into natural language with clear explanations of actions.

---



**Guided responses.** Actionable step-by-step guidance for incident response, including directions for triage, investigation, containment, and remediation.

# End of presentation

